

I.LAB WEB APPLICATION TESTING

BOOKSERVICE LAB – PROXY, INPUT HANDLING, SQL ERROR CHECKING, XPATH LOGIN TESTING

1. Mục tiêu

- Hiểu quy trình kiểm thử ứng dụng web trong môi trường lab cô lập.
- Tự dựng một ứng dụng web mục tiêu giống logic chương 5.
- Thực hành:
 - cấu hình web server và database
 - tạo ứng dụng web có login, trang chi tiết sách, form cập nhật hồ sơ và vùng yêu cầu xác thực
 - dùng Burp Suite để chặn và sửa request
 - quan sát xử lý input ở phía server
 - nhận diện lỗi SQL trên tham số `id`
 - nhận diện lỗi XPath ở trang login
 - thu thập bằng chứng và viết báo cáo pentest
- Chỉ thực hiện trong **lab nội bộ**, không áp dụng trên hệ thống thật.

2. Mô hình lab

Máy Attacker (Kali Linux)

- Vai trò: kiểm thử ứng dụng web
- IP ví dụ: 192.168.56.101

Máy Target (Ubuntu Server/Desktop hoặc Windows + XAMPP)

- Vai trò: host ứng dụng web BookService Lab
- IP ví dụ: 192.168.56.102

Mạng

- Cả 2 máy cùng mạng **Host-only** hoặc **NAT Network**
- Không public Internet
- Nên snapshot trước khi thực hành

Ứng dụng mục tiêu: BookService Lab

Ứng dụng gồm 4 thành phần chính:

- /login.php → trang đăng nhập
- /index.php → trang chính liệt kê sách
- /bookdetail.php?id=1 → trang chi tiết sách lấy dữ liệu từ SQL
- /profile.php → form cập nhật thông tin người dùng
- /admin.php → khu vực yêu cầu xác thực

Trong chương 5 ví dụ minh họa phần web app testing có URL `bookdetail.aspx?id=1` để lấy chi tiết sách từ backend SQL, và phần đăng nhập sử dụng XML/XPath để xác thực. Tài liệu cũng mô tả việc sửa trực tiếp các field như user, pass, email trong proxy trước khi forward request.

3. Công cụ sử dụng

Công cụ	Máy	Mục đích
Terminal	Kali/Target	chạy lệnh
Firefox	Kali	truy cập web app
Burp Suite Community	Kali	chặn/sửa request
Apache2 + PHP	Target	chạy ứng dụng web
MariaDB/MySQL	Target	lưu dữ liệu sách
nano / vim	Target	tạo file ứng dụng
Browser DevTools	Kali	xem cookie/session
curl	Kali	gửi request kiểm tra
công cụ chụp màn hình	Kali	lưu bằng chứng

4. Thiết kế ứng dụng mục tiêu

4.1. Cấu trúc thư mục

Trên máy Target, tạo thư mục:

```
/var/www/html/bookservice
```

Bên trong gồm:

```
bookservice/
├── config.php
├── index.php
├── login.php
├── authenticate.php
├── logout.php
├── bookdetail.php
└── profile.php
```

```
|— updateprofile.php
|— admin.php
|— users.xml
|— assets/
```

4.2. Logic của từng trang

login.php

- Hiển thị form username và password
- Form gửi POST sang authenticate.php

authenticate.php

- Đọc file users.xml
- Dùng XPath để kiểm tra tài khoản
- Nếu đúng thì tạo session \$_SESSION['user']
- Nếu sai thì báo lỗi

index.php

- Kết nối DB
- Liệt kê danh sách sách
- Mỗi sách có link bookdetail.php?id=...

bookdetail.php

- Nhận tham số id từ URL
- Tạo câu SQL lấy dữ liệu sách theo id
- Hiển thị tên sách, tác giả, mô tả

profile.php

- Chỉ truy cập được sau khi đăng nhập
- Hiển thị form cập nhật email, phone, city
- Form gửi sang updateprofile.php

updateprofile.php

- Nhận dữ liệu từ form
- Hiển thị lại kết quả đã cập nhật
- Mục tiêu là để sinh viên chặn request bằng Burp và sửa giá trị trước khi forward

admin.php

- Chỉ cho vào khi đã login
- Dùng để minh họa authenticated area

5. Giai đoạn chuẩn bị môi trường

Bước 1: (Target – Ubuntu) Kiểm tra IP

```
ip a
```

Ghi lại IP, ví dụ:

```
192.168.56.102
```

Bước 2: (Attacker – Kali) Kiểm tra IP

```
ip a
```

Ghi lại IP:

```
192.168.56.101
```

Bước 3: (Attacker – Kali) Kiểm tra kết nối tới Target

```
ping -c 4 192.168.56.102
```

Nếu có phản hồi → OK

Bước 4: (Target – Ubuntu) Cài Apache, PHP, MariaDB

```
sudo apt update
sudo apt install apache2 mariadb-server php php-mysql php-xml libapache2-
mod-php -y
sudo systemctl enable apache2
sudo systemctl start apache2
sudo systemctl enable mariadb
sudo systemctl start mariadb
```

Bước 5: (Target – Ubuntu) Kiểm tra web server

Mở browser trên Target hoặc từ Kali:

```
http://192.168.56.102
```

Nếu thấy trang mặc định Apache → OK

Bước 6: (Target – Ubuntu) Tạo thư mục ứng dụng

```
cd /var/www/html
sudo mkdir bookservice
cd bookservice
```

Bước 7: (Target – Ubuntu) Phân quyền tạm thời để dễ tạo file

```
sudo chown -R $USER:$USER /var/www/html/bookservice
```

6. Tạo cơ sở dữ liệu BookApp

Bước 8: (Target – Ubuntu) Đăng nhập MariaDB

```
sudo mysql
```

Bước 9: Tạo database và bảng

```
CREATE DATABASE BookApp;
USE BookApp;
```

```
CREATE TABLE BOOKMASTER (
    id INT PRIMARY KEY AUTO_INCREMENT,
    title VARCHAR(100),
    author VARCHAR(100),
    description TEXT
);
```

```
INSERT INTO BOOKMASTER (title, author, description) VALUES
('Dont Make Me Think', 'Steve Krug', 'Sach ve usability va web design'),
('The Web Application Hackers Handbook', 'Stuttard', 'Sach ve bao mat ung dung web'),
('Penetration Testing', 'Georgia Weidman', 'Sach thuc hanh pentest');
```

Bước 10: Kiểm tra dữ liệu

```
SELECT * FROM BOOKMASTER;
EXIT;
```

Kết quả mong đợi: có 3 bản ghi với id lần lượt 1, 2, 3

7. Tạo file XML người dùng cho login

Bước 11: (Target – Ubuntu) Tạo `users.xml`

```
nano /var/www/html/bookservice/users.xml
```

Nội dung:

```
<?xml version="1.0" encoding="UTF-8"?>
<users>
  <user>
    <username>admin</username>
    <password>admin123</password>
    <email>admin@book.local</email>
    <role>admin</role>
  </user>
  <user>
    <username>student</username>
    <password>student123</password>
    <email>student@book.local</email>
    <role>user</role>
  </user>
</users>
```

8. Tạo mã nguồn ứng dụng

Bước 12: Tạo file `config.php`

```
nano /var/www/html/bookservice/config.php
```

Nội dung:

```
<?php
session_start();

$host = "localhost";
$user = "root";
$pass = "";
$db    = "BookApp";

$conn = new mysqli($host, $user, $pass, $db);
if ($conn->connect_error) {
    die("Database connection failed: " . $conn->connect_error);
}
?>
```

Bước 13: Tạo file `login.php`

```
nano /var/www/html/bookservice/login.php
```

Nội dung:

```
<!DOCTYPE html>
<html>
<head>
```

```

        <meta charset="utf-8">
        <title>BookService Login</title>
</head>
<body>
    <h2>BookService Login</h2>
    <form action="authenticate.php" method="post">
        Username: <input type="text" name="txtUser"><br><br>
        Password: <input type="password" name="txtPass"><br><br>
        <button type="submit">Login</button>
    </form>
</body>
</html>

```

Bước 14: Tạo file `authenticate.php`

```
nano /var/www/html/bookservice/authenticate.php
```

Nội dung:

```

<?php
session_start();

$user = $_POST['txtUser'] ?? '';
$pass = $_POST['txtPass'] ?? '';

$xml = simplexml_load_file("users.xml");

// Cố tình viết theo kiểu lab để mô phỏng đúng tinh thần chương 5
$query = "//user[username/text()='\" . $user . "\" and password/text()='\" .
$pass . "\"]";

$result = $xml->xpath($query);

if ($result && count($result) > 0) {
    $_SESSION['user'] = (string)$result[0]->username;
    $_SESSION['role'] = (string)$result[0]->role;
    header("Location: admin.php");
    exit;
} else {
    echo "<h3>Login failed</h3>";
    echo "<p>Invalid username or password</p>";
    echo "<p><a href='login.php'>Back</a></p>";
}
?>

```

Giải thích:

- File này cố tình dùng XPath ghép chuỗi trực tiếp để sinh viên nhìn thấy nguy cơ xử lý input không an toàn.
- Điều này bám rất sát mô tả trong chương 5: ứng dụng xác thực bằng XML/XPath, và request login là nơi phù hợp để quan sát lỗi xử lý input.

Bước 15: Tạo file `index.php`

```
nano /var/www/html/bookservice/index.php
```

Nội dung:

```
<?php
include "config.php";
$result = $conn->query("SELECT id, title, author FROM BOOKMASTER");
?>
<!DOCTYPE html>
<html>
<head>
    <meta charset="utf-8">
    <title>BookService</title>
</head>
<body>
    <h1>BookService Main Page</h1>
    <p><a href="login.php">Login</a></p>
    <h3>Available Books</h3>
    <ul>
        <?php while($row = $result->fetch_assoc()): ?>
            <li>
                <?php echo htmlspecialchars($row['title']); ?> -
                <a href="bookdetail.php?id=<?php echo $row['id'];
?>">More Details</a>
            </li>
        <?php endwhile; ?>
    </ul>
</body>
</html>
```

Trang chính có danh mục sách và link “More Details” dẫn tới URL dạng `bookdetail.aspx?id=1`. Ở đây ta mô phỏng đúng ý tưởng đó bằng `bookdetail.php?id=1`.

Bước 16: Tạo file `bookdetail.php`

```
nano /var/www/html/bookservice/bookdetail.php
```

Nội dung:

```
<?php
include "config.php";

$id = $_GET['id'] ?? '1';

// Cố tình ghép chuỗi trực tiếp để mô phỏng lab
$sql = "SELECT * FROM BOOKMASTER WHERE id = '$id'";
$result = $conn->query($sql);

if (!$result) {
    die("SQL Error: " . $conn->error);
}

$row = $result->fetch_assoc();
```



```

?>
<!DOCTYPE html>
<html>
<head>
    <meta charset="utf-8">
    <title>Book Detail</title>
</head>
<body>
    <h2>Book Detail</h2>

    <?php if($row): ?>
        <p><strong>Title:</strong> <?php echo
htmlspecialchars($row['title']); ?></p>
        <p><strong>Author:</strong> <?php echo
htmlspecialchars($row['author']); ?></p>
        <p><strong>Description:</strong> <?php echo
htmlspecialchars($row['description']); ?></p>
    <?php else: ?>
        <p>No record found.</p>
    <?php endif; ?>

    <p><a href="index.php">Back</a></p>
</body>
</html>

```

Giải thích:

- File này mô phỏng đúng điểm nhấn của chương 5: có tham số `id`, backend lấy dữ liệu từ SQL, và sinh viên có thể thay đổi giá trị `id` để quan sát phản hồi. Tài liệu mô tả chính xác kiểu URL này và việc dùng một dấu nhảy đơn để làm lộ lỗi SQL cú pháp.

Bước 17: Tạo file `profile.php`

```
nano /var/www/html/bookservice/profile.php
```

Nội dung:

```

<?php
session_start();
if (!isset($_SESSION['user'])) {
    header("Location: login.php");
    exit;
}
?>
<!DOCTYPE html>
<html>
<head>
    <meta charset="utf-8">
    <title>Profile Update</title>
</head>
<body>
    <h2>Update Profile</h2>
    <form action="updateprofile.php" method="post">

```

```

        Username: <input type="text" name="username" value="<?php echo
$_SESSION['user']; ?>" readonly><br><br>
        Email: <input type="text" name="email"
value="student@book.local"><br><br>
        Phone: <input type="text" name="phone"
value="0900000000"><br><br>
        City: <input type="text" name="city" value="Ha Noi"><br><br>
        <button type="submit">Save</button>
    </form>
</body>
</html>

```

Bước 18: Tạo file `updateprofile.php`

```
nano /var/www/html/bookservice/updateprofile.php
```

Nội dung:

```

<?php
session_start();
if (!isset($_SESSION['user'])) {
    header("Location: login.php");
    exit;
}

$username = $_POST['username'] ?? '';
$email    = $_POST['email'] ?? '';
$phone    = $_POST['phone'] ?? '';
$city     = $_POST['city'] ?? '';
?>
<!DOCTYPE html>
<html>
<head>
    <meta charset="utf-8">
    <title>Profile Updated</title>
</head>
<body>
    <h2>Profile Updated</h2>
    <p><strong>Username:</strong> <?php echo htmlspecialchars($username);
?></p>
    <p><strong>Email:</strong> <?php echo htmlspecialchars($email);
?></p>
    <p><strong>Phone:</strong> <?php echo htmlspecialchars($phone);
?></p>
    <p><strong>City:</strong> <?php echo htmlspecialchars($city); ?></p>
    <p><a href="profile.php">Back</a></p>
</body>
</html>

```

Trang này có thể hiểu rằng dữ liệu form có thể bị chỉnh trực tiếp trong proxy trước khi đến server. Đó cũng là đúng ví dụ sách nêu: server sẽ xử lý theo request đã bị sửa nếu không tự xác thực lại dữ liệu nhận được.

Bước 19: Tạo file `admin.php`

```
nano /var/www/html/bookservice/admin.php
```

Nội dung:

```
<?php
session_start();
if (!isset($_SESSION['user'])) {
    header("Location: login.php");
    exit;
}
?>
<!DOCTYPE html>
<html>
<head>
    <meta charset="utf-8">
    <title>Admin Area</title>
</head>
<body>
    <h2>Authenticated Area</h2>
    <p>Welcome, <?php echo htmlspecialchars($_SESSION['user']); ?></p>
    <ul>
        <li><a href="profile.php">Profile</a></li>
        <li><a href="index.php">Book List</a></li>
        <li><a href="logout.php">Logout</a></li>
    </ul>
</body>
</html>
```

Bước 20: Tạo file `logout.php`

```
nano /var/www/html/bookservice/logout.php
```

Nội dung:

```
<?php
session_start();
session_destroy();
header("Location: login.php");
exit;
?>
```

9. Kiểm tra ứng dụng sau khi dựng xong

Bước 21: (Attacker – Kali) Mở ứng dụng

Truy cập:

```
http://192.168.56.102/bookservice/index.php
```

Kết quả mong đợi:

- Thấy trang chủ BookService
- Có danh sách sách
- Có link `More Details`

Bước 22: Kiểm tra trang login

`http://192.168.56.102/bookservice/login.php`

Dùng tài khoản:

- `admin / admin123`
- `student / student123`

Nếu login thành công và chuyển sang `admin.php` → OK

Bước 23: Kiểm tra trang detail

Truy cập:

`http://192.168.56.102/bookservice/bookdetail.php?id=1`

Nếu thấy thông tin sách → OK

Bước 24: Kiểm tra profile

Sau khi login, mở:

`http://192.168.56.102/bookservice/profile.php`

Nếu thấy form update profile → OK

10. Cấu hình Burp Suite

Bước 25: (Attacker – Kali) Mở Burp Suite

- Applications → Web Application Analysis → Burp Suite
- Temporary project → Start

Bước 26: Kiểm tra listener

- Proxy → Options
- Listener mặc định `127.0.0.1:8080`

Bước 27: Cấu hình Firefox dùng proxy

- Settings → Network Settings
- Manual Proxy:
 - HTTP Proxy: 127.0.0.1
 - Port: 8080

Bước 28: Bật intercept

- Proxy → Intercept
- Chuyển sang Intercept is on

11. Giai đoạn thực hành chi tiết

11.1. Thực hành 1 – Quan sát request login

Bước 29: (Attacker – Kali) Truy cập login page

`http://192.168.56.102/bookservice/login.php`

Bước 30: Nhập thử tài khoản

- Username: `student`
- Password: `student123`

Bước 31: Quan sát request trong Burp

Sinh viên cần ghi nhận:

- Method: `POST`
- Tham số: `txtUser`, `txtPass`
- Header
- Cookie nếu có

Bước 32: Forward request

Nếu login thành công → chuyển sang `admin.php`

Kết quả học tập:

- Biết request POST nhìn như thế nào

- Biết dữ liệu đăng nhập đi qua proxy ra sao

11.2. Thực hành 2 – Sửa request ở form profile

Proxy có thể sửa trực tiếp các trường như `User`, `Pass`, `Email`, và server sẽ chấp nhận dữ liệu đã sửa nếu không xác thực lại phía server.

Bước 33: (Attacker – Kali) Sau khi login, mở:

`http://192.168.56.102/bookservice/profile.php`

Bước 34: Điền thông tin bình thường

- Email: `student@book.local`
- Phone: `0900000000`
- City: `Ha Noi`

Bước 35: Nhấn Save và chặn request trong Burp

Quan sát:

- request `POST`
- các field `username`, `email`, `phone`, `city`

Bước 36: Sửa 1 trường trong request trước khi forward

Ví dụ:

- sửa `city` từ `Ha Noi` thành `Da Nang`
- hoặc sửa `email` thành giá trị khác

Bước 37: Forward request

Kết quả mong đợi:

- Trang `updateprofile.php` hiển thị đúng giá trị đã bị sửa trong Burp

Kết luận sự phạm:

- Sinh viên hiểu rằng dữ liệu gửi từ browser không đáng tin
- Cần xác thực và kiểm tra lại phía server

11.3. Thực hành 3 – Kiểm tra tham số `id` trên URL

Mô tả rõ trang chi tiết sách dùng URL `bookdetail.aspx?id=1`, và dữ liệu được lấy ra từ bản ghi có ID tương ứng trong SQL backend.

Bước 38: (Attacker – Kali) Truy cập:

`http://192.168.56.102/bookservice/bookdetail.php?id=1`

Bước 39: Thay đổi tham số

Lần lượt thử:

```
?id=1
?id=2
?id=3
?id=99
```

Bước 40: Ghi lại phản hồi

- `id=1, 2, 3` → có bản ghi
- `id=99` → không có bản ghi

Kết quả học tập:

- Hiểu GET parameter
- Hiểu ứng dụng lấy dữ liệu theo `id`

11.4. Thực hành 4 – Quan sát lỗi xử lý SQL ở `id`

Chương 5 nêu rõ phép thử đầu tiên là thêm một dấu nháy đơn vào `id`; nếu ứng dụng ghép chuỗi SQL không an toàn, server có thể trả về lỗi cú pháp SQL.

Bước 41: (Attacker – Kali) Gửi giá trị `id` bất thường theo đúng ví dụ sự phạm

Ví dụ trên URL:

`http://192.168.56.102/bookservice/bookdetail.php?id=1'`

Bước 42: Quan sát phản hồi

Kết quả mong đợi:

- xuất hiện lỗi SQL
- hoặc thông báo kiểu `SQL Error: ...`

Bước 43: Chụp màn hình bằng chứng

Lưu các ảnh:

- URL đã nhập
- thông báo lỗi
- response trong Burp nếu có

Kết luận sự phạm:

- Sinh viên nhận diện được dấu hiệu ứng dụng ghép truy vấn SQL không an toàn
- Dừng ở mức **quan sát lỗi và ghi nhận dấu hiệu**, không đi sâu sang hậu khai thác

11.5. Thực hành 5 – Quan sát lỗi xử lý XPath ở login

Tài liệu nêu rõ ứng dụng ví dụ dùng XML/XPath để xác thực, và tại login page có thể xuất hiện lỗi XML/XPath khi input không được xử lý đúng.

Bước 44: (Attacker – Kali) Quay lại:

`http://192.168.56.102/bookservice/login.php`

Bước 45: Thử dữ liệu đầu vào bất thường để quan sát lỗi cú pháp

Thao tác:

- nhập dữ liệu bất thường ở `txtUser` và `txtPass`
- gửi request qua Burp
- theo dõi phản hồi từ server

Bước 46: Ghi nhận kết quả

Sinh viên cần ghi:

- response có lỗi XML/XPath hay không
- lỗi xuất hiện ở trạng thái nào
- request gửi đi gồm những gì

Kết luận sự phạm:

- Biết login page không chỉ để nhập tài khoản, mà còn là điểm kiểm thử input handling
- Biết phân biệt backend XML/XPath với backend SQL

11.6. Thực hành 6 – Khu vực yêu cầu xác thực và session

Bước 47: (Attacker – Kali) Login thành công

Đăng nhập bằng tài khoản hợp lệ

Bước 48: Truy cập trực tiếp `admin.php`

`http://192.168.56.102/bookservice/admin.php`

Kết quả:

- nếu đã login → xem được
- nếu chưa login → bị chuyển về `login.php`

Bước 49: Quan sát cookie/session

Trong Burp hoặc DevTools:

- xem cookie phiên
- ghi lại tên cookie
- kiểm tra sau khi logout cookie thay đổi thế nào

Bước 50: Logout

Mở:

`http://192.168.56.102/bookservice/logout.php`

Bước 51: Truy cập lại `admin.php`

Nếu bị chuyển về `login.php` → session handling cơ bản hoạt động

12. Thu thập bằng chứng

Bước 52: (Attacker – Kali) Tạo thư mục bằng chứng

```
mkdir -p ~/lab-bookservice/evidence  
mkdir -p ~/lab-bookservice/notes
```

Bước 53: Tạo file ghi chú

```
nano ~/lab-bookservice/notes/observations.txt
```

Nội dung gợi ý:

Target IP: 192.168.56.102
App: BookService Lab
Date: 2026-03-25

Pages:

- /bookservice/login.php
- /bookservice/index.php
- /bookservice/bookdetail.php?id=1
- /bookservice/profile.php
- /bookservice/admin.php

Findings observed:

- Login POST visible in Burp
- Form fields can be modified before forwarding
- SQL error visible when id is malformed
- Authenticated area requires session
- XML/XPath-based login behavior observed

Bước 54: Ảnh cần chụp

- Trang login
- Request POST login trong Burp
- Trang index có link More Details
- URL bookdetail.php?id=1
- Phản hồi lỗi khi id bất thường
- Request profile bị sửa trong Burp
- Trang admin sau login
- Trạng thái sau logout

13. Phân tích kết quả

Bước 55: Sinh viên đánh giá

- Ứng dụng có xử lý request phía server
- Proxy có thể nhìn và sửa request
- Dữ liệu từ client có thể bị thay đổi giữa đường
- Tham số `id` là điểm đầu vào quan trọng
- Login page là điểm kiểm thử xử lý input
- Session quyết định quyền vào khu vực xác thực

Bước 56: Xếp loại phát hiện

Gợi ý:

- Input validation weakness → Medium
- Verbose error disclosure → Medium
- SQL error exposure at `id` → High
- XPath input handling issue at login → High
- Session/cookie weakness nếu có → Medium

14. Phòng chống

Bước 57: Sinh viên đề xuất khắc phục

- Không ghép chuỗi trực tiếp khi tạo truy vấn SQL
- Không ghép trực tiếp input vào biểu thức XPath
- Validate input phía server
- Không hiển thị lỗi nội bộ cho người dùng
- Áp dụng prepared statements
- Quản lý session chặt chẽ
- Thêm thuộc tính bảo vệ cho cookie
- Kiểm tra quyền truy cập trước khi vào vùng xác thực

15. Kết luận lab

Nội dung đã thực hiện:

- ✓ Dựng web app mục tiêu giống chương 5
- ✓ Tạo login XML/XPath
- ✓ Tạo trang `bookdetail?id=...` dùng SQL
- ✓ Tạo form update profile để sửa request

- ✓ Tạo khu vực yêu cầu xác thực
- ✓ Dùng Burp Suite để chặn và sửa request
- ✓ Quan sát lỗi xử lý input
- ✓ Thu thập bằng chứng
- ✓ Chuẩn bị dữ liệu cho báo cáo pentest

II.KHUNG BÁO CÁO PENTEST

Cấu trúc này bám theo file mẫu của bạn: **Executive Summary** → **Scope** → **Methodology** → **Attack Details** → **Findings** → **Evidence** → **Risk Analysis** → **Recommendations** → **Conclusion**.

1. Executive Summary

Trong quá trình kiểm thử ứng dụng web BookService Lab, nhóm đã tiến hành dựng và đánh giá một ứng dụng web mô phỏng có chức năng đăng nhập, xem chi tiết sách, cập nhật hồ sơ và truy cập khu vực yêu cầu xác thực.

Kết quả cho thấy:

- HTTP request/response có thể bị quan sát và chỉnh sửa bằng web proxy
- Tham số đầu vào ở một số chức năng được xử lý chưa an toàn
- Trang chi tiết sách để lộ lỗi xử lý truy vấn SQL khi tham số id bất thường
- Cơ chế đăng nhập dựa trên XML/XPath có dấu hiệu xử lý input chưa an toàn
- Khu vực xác thực hoạt động dựa trên session

Mức độ rủi ro tổng quan: **MEDIUM đến HIGH** trong phạm vi lab.

2. Scope

- Phạm vi:
 - ứng dụng BookService Lab nội bộ
 - chức năng login
 - chức năng book detail
 - chức năng profile update
 - authenticated area
- Ngoài phạm vi:
 - hệ thống thật
 - Internet public
 - hậu khai thác hệ điều hành

3. Methodology

1. Chuẩn bị môi trường lab
2. Dựng ứng dụng web mục tiêu
3. Cấu hình proxy
4. Kiểm tra request/response
5. Kiểm tra input handling
6. Quan sát lỗi xử lý SQL/XPath
7. Kiểm tra session
8. Thu thập bằng chứng
9. Báo cáo

4. Attack Details

Kỹ thuật:

- Web proxy interception
- Request modification
- Input validation testing
- SQL error observation
- XPath error observation
- Session inspection

Các bước:

1. Dựng ứng dụng BookService Lab
2. Tạo database và XML users
3. Truy cập ứng dụng từ Kali
4. Chặn request login
5. Sửa request profile
6. Thay đổi tham số `id`
7. Ghi nhận phản hồi lỗi
8. Quan sát session và logout

5. Findings

ID	Mô tả	Mức độ
WEB-01	Form profile chấp nhận dữ liệu đã bị sửa trong proxy	MEDIUM
WEB-02	Ứng dụng hiển thị lỗi chi tiết khi tham số <code>id</code> bất thường	MEDIUM
WEB-03	Chức năng book detail có dấu hiệu xử lý truy vấn SQL không an toàn	HIGH

ID	Mô tả	Mức độ
WEB-04	Chức năng login dùng XML/XPath có dấu hiệu xử lý input chưa an toàn	HIGH
WEB-05	Session là điều kiện truy cập admin area	INFO/MEDIUM

6. Evidence

- Ảnh request login trong Burp
- Ảnh request profile bị sửa
- Ảnh URL `bookdetail.php?id=1`
- Ảnh lỗi khi `id` bất thường
- Ảnh vùng `admin.php` sau login
- Ảnh sau logout không truy cập được admin

7. Risk Analysis

- Người dùng/ứng dụng không nên tin dữ liệu từ trình duyệt
- Nếu xử lý input không đúng, có thể dẫn đến lộ lỗi nội bộ
- Lỗi xử lý SQL/XPath có thể ảnh hưởng tính bí mật và toàn vẹn dữ liệu
- Session nếu quản lý yếu có thể ảnh hưởng kiểm soát truy cập

8. Recommendations

- Dùng prepared statements
- Tránh ghép chuỗi trực tiếp vào XPath
- Validate server-side
- Ấn lỗi hệ thống khỏi người dùng
- Quản lý session/cookie an toàn
- Thực hiện secure coding review cho login, detail, profile

9. Conclusion

BookService Lab là mô hình phù hợp để sinh viên học đúng tinh thần chương 5 dùng proxy để quan sát và sửa request, kiểm tra điểm vào trên login và tham số `id`, hiểu mối liên hệ giữa client input, backend SQL/XML và session.